

AU Bank Insurance Distribution Platform (NIP)

Architecture Review Board — R0 prerequisite pack (leave-behind)

AI-DRAFTED evidence. Not ARB approval, not T4 Architecture, not Board 4, not Board 6 CIS registration, not a VA/PT pass.
HA-02: ADR / LLD / NFR win.

Document ARB-PRE-2026-09-14 · 2026-09-14 · Draft: Mahesh, Board 1 / R2

Room file: AU-NIP-R0-ARB-Walk-In.pptx · Matrices: AU-NIP-R0-ARB-Matrices.xlsx

How to use this document

This is the bank ARB leave-behind for the R0 Insurance Distribution Platform (NIP).

Open the PowerPoint in the room. Use this PDF/Word to circulate. Use the Excel workbook for matrices.

AI-DRAFTED evidence. Not ARB approval, not T4 Architecture, not Board 4, not Board 6 CIS registration, not a VA/PT pass. HA-02: ADR / LLD / NFR win.

Rule HA-02: if a paragraph here disagrees with an ADR, the LLD, the NFR catalogue or the security architecture, that source wins.

1. Business ask and sign-off — PARTIAL

Ask (admitted objective): one RM, acting as certified Specified Person, sells a complete Life policy (Term or Savings/ULIP) to one ETB customer of one Group A insurer, end to end, with suitability, customer-device OTP consent, customer-device payment, reconciled issuance and immutable audit (R0-ASSISTED-LIFE-SALE).

Licence: IRDAI Composite Corporate Agency CA0515. Scope is in BOOT.md. CR-010 registered the workstream. CR-015 restates Savings/ULIP (CANDIDATE transcribed; HUMAN T4 outstanding).

This pack does not fill a bank new-application signature block, a budget memo, or a Product Owner counter-signature on GOV-004. Rajal owns that process.

2. Critical Information System classification — HUMAN-REQUIRED

Architecture proposes class Critical Information System (CIS). Processing in AWS ap-south-1 with DR replicas in ap-south-2 only. No regulated data outside India.

Shailja S (Board 6) and bank Information Security / CISO enter the bank CIS register. Mahesh does not. A lower class would be a written risk acceptance, not a design simplification.

3–4. Solution architecture · current vs target — READY (unsigned)

SAD: docs/platform/ws3-platform/03-solution-architecture-r0.md plus R0-HLD.md and R0-LLD.md. Human T4 Architecture is outstanding.

Current-state is H0/R0 as designed, not as running in prod. Target-state is the North Star at horizons H1–H3. Do not read H1–H3 as admitted scope.

5. Data-flow and trust boundaries — READY (unsigned)

Inbound: device → Cloudflare → F5-XC → Amazon API Gateway → Internal ALB → nip-web / NIP BFF (ADR-018).

Outbound: Hub → adapter → Apigee → 1SB (ADR-020). 1SB allowlists Apigee IPs, not spoke NAT EIPs.

Internal bank API: Apigee private → AD-verify / EBS. Forbidden: Cloudflare/F5 hairpin.

Payment: session-create outbound via Apigee; customer 3-DS on own device; callback inbound on a separate API Gateway route (TB-6).

Trust boundaries TB-1...TB-7 live in 04-security-architecture.md. Deepali still owns the threat-model signature.

6–9. Integration, capacity, availability, DR

Runtime integrations I-01...I-12 and third parties are in the Excel workbook (sheets 04–06).

Capacity (CAP-A*, unapproved by Product): ~100 journey starts/hour BAU, ~7/minute at Q4 peak. R0 is correctness-constrained. Do not scale from CPU.

Sale-path availability 99.9%. RTO ≤ 1 hour. Transactional RPO ≤ 5 minutes. Audit RPO 0. Unproven until S09 drills (NFR-DR-04).

DR: warm standby ap-south-2. Cache/MSK/OpenSearch are not replicated. Proof is a timed drill, not the picture.

10–12. Security, VA/PT, SBOM

Security architecture is an input to Board 4, not a Board 4 verdict. ADR-010 remainder is Deepali's acceptance.

VA/PT is NOT-YET. CI currently runs Checkstyle, Spotless, ArchUnit, JaCoCo and lockfile SCA. Do not tell ARB a pentest passed.

SBOM: 14 Gradle lockfiles, 137 unique runtimeClasspath coordinates (Excel sheet 12). Java 21, Spring Boot 3.5.16. CycloneDX CI is still S09. Flutter pubspec.lock is not merged.

13–15. Data classification, IAM/PAM, logging

PUBLIC / INTERNAL / CONFIDENTIAL / RESTRICTED + [P][F][H][K]. India residency TI-08 / FF-08.

Workforce identity stays Bank AD (TI-01), reached via the AD-verify API through Apigee private. Never LDAP from EKS.

Privileged AWS access is bank PAM / IAM Identity Center. Application IAM is IRSA per deployable.

CloudTrail and CloudWatch are both mandatory. OpenSearch holds operational logs, never evidence (ADR-013). Audit is INSERT-only + S3 Object Lock (TI-07).

16–19. Third parties, cloud RACI, lifecycle, exit

No new subcontractor: R0 attaches to already-procured bank platforms (Cloudflare, F5-XC, Apigee, GitLab, AWS, 1SB). 1SB is a provider route (TI-04), not a domain dependency.

Five Control Tower accounts: shared-services, security, network, uat, prod. No separate dev. No CUG. Attach to AU-CTO-NETWORK.

Java 21 and Spring Boot 3.5 are in support. Keycloak / Flutter / EKS pins confirmed by Amit + Shivanshi at S09.

Exit: turn off the adapter, keep the evidence. Three exits are not the same change (replace 1SB / leave AWS / decommission NIP). Kubernetes PVC is not a system of record.

Named holds that would be fair

CIS register (row 2). Product volume sign-off (row 7). Deepali Board 4 (row 10). VA/PT plan date (row 11). Apigee written IPs (row 6). Human T4 Architecture (rows 3–4).

Agents draft. They do not sign.

Readiness dashboard (19 bank prerequisites)

#	Bank ARB prerequisite	Readiness	Named gap / owner
1	Business ask and sign-off for new technical or application requirement	PARTIAL	Rajal Product sign-off of CAP-A volumes and CR-015 T4. PO counter-signature on GOV-004 still outstanding. This pack does not invent a business BRD signature.
2	Critical Information System classification	HUMAN-REQUIRED	Shailja + bank InfoSec / CISO. Architecture proposes Critical. The bank CIS register is the SoT.
3	Solution Architecture Document	READY (unsigned)	Human T4 Architecture.
4	Current-state and target-state architecture	READY (unsigned)	Do not read H1–H3 as admitted scope.

#	Bank ARB prerequisite	Readiness	Named gap / owner
5	Data-flow and trust-boundary diagrams	READY (unsigned)	Split plane ADR-020 is now on topology/payment. Security mermaid in §2 of this change aligns TB-5/TB-7 to Apigee. Deepali still owns the threat-model signature.
6	Integration and dependency matrix	READY (compiled)	External rows OPEN: Apigee onboard (DEP-20260914-apg), VPN/DX (DEP-20260824-dx1), bank UAT slot (DEP-002).
7	Infrastructure sizing and capacity assessment	PARTIAL	CAP-A1...A7 are assumptions, not an approved business baseline (NFR-OPEN-1, owner Rajal). R0 is correctness-constrained, not throughput-constrained.
8	Availability, RTO and RPO of base product	READY (unsigned)	Sale-path 99.9%. RTO ≤ 1 h, RPO ≤ 5 min transactional, RPO 0 audit. Unproven until S09 drills (NFR-DR-04).
9	DR architecture and failover mechanism	READY (unsigned)	Warm standby ap-south-2. Cache/MSK/OpenSearch not replicated (D13–D15). Proof is a timed Ansible drill, not the picture.
10	Security architecture (as per Security NFR)	PARTIAL	Deepali Board 4 human. ADR-010 remainder (pod→Apigee inspection) is her acceptance, not Architecture's.
11	VA/PT and secure-code-review	NOT-YET	No VA/PT report exists. Swapnali + Deepali: SAST in pipeline now; DAST/VA/PT before UAT exit / S11–S12. Do not tell ARB a pentest passed.
12	SBOM / software dependency inventory	PARTIAL	CycloneDX/SPDX CI artefact still to be wired (S09). Flutter pubspec.lock is a second inventory.
13	Data classification and data residency	READY (unsigned)	Shailja S02-G5/G6. GAP-016 residual on attribute-level BA ratification.
14	IAM / PAM design	PARTIAL	Application IAM is designed. Privileged Access Management for AWS console / break-glass is bank PAM + Deepali; not a second IdP we invent.
15	Logging and monitoring design	READY (unsigned)	Operational logs RET-OPERATIONAL 90 d. Audit is not logging (TI-07).
16	Third-party and subcontractor details	READY (compiled)	1SB is a provider route, not a domain dependency (TI-04). Insurers underwrite (TI-03).
17	Cloud architecture and shared-responsibility matrix	READY (compiled)	Attach to AU-CTO-NETWORK; five Control Tower accounts; no CUG.
18	Technology lifecycle and end-of-support assessment	READY (compiled)	Java 21 and Spring Boot 3.5 are in support. Keycloak / Flutter / EKS pin to be confirmed by Amit + Shivanshi at S09.
19	Exit, portability and decommissioning strategy	READY (compiled)	1SB replaceable at the adapter. Data exits as Aurora + S3 WORM in India. Kubernetes PVC is not a SoR.

CIS classification proposal (not a register entry)

Field	Proposed value
System name	AU Bank Insurance Distribution Platform (NIP) — R0 assisted Life
Proposed class	Critical Information System (CIS)
Why not “High” or below	The platform stores and processes CIF-derived customer identity, PAN and other KYC identifiers, health/suitability attributes, payment orchestration state, and 7-year immutable audit. A confidentiality, integrity or availability failure is a regulatory and customer-harm event, not only an operational inconvenience.
R0 processing location	AWS ap-south-1 (Mumbai). DR replicas ap-south-2 (Hyderabad) only. No regulated data outside India (TI-08, FF-08).
Internet exposure	Inbound: Cloudflare → F5-XC → Amazon API Gateway only (ADR-018). No public ALB, no public datastore. Outbound: Apigee (ADR-020).
Privileged access	IRSA per deployable; bank IAM Identity Center / PAM for humans; Keycloak admin console is not a bank-user UI.

Data-flow index

Flow	Picture
RM / NIP-APP inbound	Cloudflare → F5-XC → API Gateway → Internal ALB → nip-web / NIP BFF (ADR-018)
Provider outbound	Hub → #15 adapter → Apigee → 1SB (ADR-020). 1SB allowlists Apigee IPs.
Internal bank API	Adapter / Customer → Apigee private → AD-verify / EBS. Forbidden: Cloudflare/F5 hairpin.
Payment	Session-create out via Apigee; customer 3-DS on own device; callback in on a separate API Gateway route (TB-6).
Trust boundaries	TB-1...TB-7 in 04-security-architecture.md §2

Sign-off routing

Seat	What they sign	What they must not be asked to sign for Architecture
Rajal (R1)	Business ask, CAP-A baseline, CR-015 product acceptance	Technology choice
Mahesh (R2) human T4	SAD / HLD / LLD / this pack as architecture evidence	Deepali's security residual, Shailja's CIS class
Deepali (R8) human	Board 4, ADR-010 remainder, VA/PT scope, PAM pattern	Product behaviour
Shailja (R9) human	CIS class, classification/retention, residency attestation	A pentest result
Shivanshi (R10)	S09 vending, Apigee onboard, DR drill records	Architecture structure
Aarti	Physical model / PITR / WORM restore	Service boundaries
Swapnali (R7)	Evidence sufficiency of VA/PT and SAST	Waiving a non-waivable control
Kalpana (R12)	Whether ARB is on the critical path this increment	The content of a specialist verdict

Control Tower accounts

Account	Holds	If it is compromised
shared-services	Terraform state pattern, ECR, shared runners	Build supply chain — not customer data at rest
security	CloudTrail, GuardDuty, Security Hub, Config	Detection failure; not the sale-path datastore
network	Inspection VPCs, attachments	Egress / routing; production data does not live here
uat	vpc-dev (synthetic) + vpc-uat (masked)	Two route tables so stubs cannot reach prod CBS
prod	Real ETB, real AD-verify, real 1SB	The CIS blast radius

Exit scenarios

Exit	What we keep	What we turn off	Timebox (draft)
Replace 1SB	Hub contract, canonical model, audit, policies already issued	#15 adapter module + Apigee 1SB product	Adapter-swap; no domain migration (TI-04)
Leave AWS (extreme)	Logical model, WORM export, Terraform as documentation of intent	Accounts, KMS, network	Multi-quarter; India residency still binds the destination
Decommission NIP	7-year evidence (audit, consent, suitability, policy documents)	Compute, sessions, operational logs, IdP for this programme	Retention clock starts from event time / policy termination per information model §2.2

Integration I-01...I-12, cloud RACI, lifecycle pins and the 137-coordinate SBOM are in the Excel workbook.